06/30/2010
Revised 03/03/2026

OPR: WVOT Cybersecurity

COMPLIANCE WITH THIS PUBLICATION IS MANDATORY

Publications are available online at:
https://sites.google.com/wv.gov/othub/policy-governance/ot-policies

Questions and change recommendations related to this publication shall be directed to this publication's Office of Primary Responsibility (OPR). This plan shall be reviewed every two years to ensure continued alignment with current legal, operational, and strategic requirements. Revisions will be undertaken as necessary.

SUMMARY OF VERSIONS AND CHANGES

Version	Date	Revision Description
	07/01//2015	Added Change Log History
	03/03/2026	Reformatted, removed Appendix A Risk Matrix and re-numbered the other Appendices

1. PURPOSE

1.1. This plan provides the basis of appropriate response to security incidents that threaten or compromise the confidentiality, integrity, and availability of State information assets, systems, and networks that deliver information.

2. SCOPE

2.1. This plan applies to all departments (including agencies, boards, authorities, and commissions) within the Executive Branch of WV State Government, excluding constitutional officers, the WV Board of Education, the WV Department of Education, and the county boards of education that have access to or use State-provided resources.

2.2. Where there are plans in place which provide less restrictions or security than this policy, those plans will be superseded by this plan. In instances where existing state and federal laws, regulations, policies, and plans are more restrictive than this plan, the more restrictive provisions will prevail.

REPORT EVERY SUSPECTED INCIDENT IMMEDIATELY AT https://wv.accessgov.com/technology/Forms/Page/incident-reporting/incident-reporting/ OR BYCALLING THE WVOT SERVICE DESK AT 877-558-9966. IMMEDIATELY AFTER REPORTING TAKE TIME TO READ AND UNDERSTAND THIS PLAN DELAYS IN REPORTING CAN CAUSE ADDITIONAL, PREVENTABLE CONSEQUENCES

3. POLICY

3.1. Defining Security Incidents

3.1.1. A Security Incident is any event that involves misuse of computing resources or is disruptive to normal system or data processing operations. Examples include, but are not limited to the following:

3.1.1.1. Loss of information confidentiality (data theft, accidental disclosure);

3.1.1.2. Compromise of information integrity (damage to data or unauthorized modification or deletion);

3.1.1.3. Theft of, or damage to, physical IT assets including computers, storage devices, printers, etc;

3.1.1.4. Denial of service (DoS) attack;

3.1.1.5. Misuse of services, information, or assets;

3.1.1.6. Overt threat of system interruption or failure;

3.1.1.7. Loss of power to a critical system;

3.1.1.8. Loss of connectivity to a critical system;

3.1.1.9. Infection of systems by unauthorized or malicious software or configurations;

3.1.1.10. Failed login attempts, exceeding the amount required to lock an account;

3.1.1.11. Unauthorized changes to State-owned hardware, software, or configuration;

3.1.1.12. Reports of unusual system behavior; and

3.1.1.13. Intrusion detection alerts or alarms.

3.1.2. Security incidents range in severity from Non-Critical to Critical. The categorization of an incident, according to its severity, will trigger the appropriate response; therefore, triage and categorization of an incident is critical to its proper management (Appendix A). For this reason, triage and categorization should occur after it is reported, by incident managers, not by reporters.

3.1.2.1. Note: It is most important to first report the incident (https://wv.accessgov.com/technology/Forms/Page/incident-reporting/incident-reporting/), and not to categorize the incident severity prior to reporting.

3.2. Defining Non-Critical Security Incidents

3.2.1. A non-critical security incident is one with either low or acceptable risk to the State and its systems. Examples include, but are not limited to the following:

3.2.1.1. Employees accessing prohibited websites that do not jeopardize the State's network;

3.2.1.2. Violating applicable information security policies and/or procedures deemed not to involve critical operations or impact;

3.2.1.3. Any security incident that is restricted to a single non-critical computer or system; and

3.2.1.4. Common system failure with routine recovery as standard operating procedure.

3.3. Defining Critical Security Incidents

3.3.1. A critical security incident is one with **high impact** and **high threat**, which can result in both high risk and great vulnerability to the State and its systems. Examples include, but are not limited to the following:

3.3.1.1. Loss of system functionality;

3.3.1.2. Theft of confidential and/or sensitive information;

3.3.1.3. Interruption of network services;

3.3.1.4. Disruption or denial of service of critical systems (ex: clinical decision-support applications, financial reporting systems, mailing systems and electronic medical records information);

3.3.1.5. Theft of a device with legally protected information,

3.3.1.6. Unauthorized access to security administrator applications or information; and

3.3.1.7. Certain policy or procedure violations.

3.3.2. Critical security incidents require that a Computer Security Incident Response Team (CSIRT) be assembled to apply appropriate response.

3.3.3. A security incident is deemed critical if it meets one of the following conditions.

3.3.3.1. An appropriate member of the CSIRT declares it to be critical;

3.3.3.2. The Chief Information Security Officer (CISO) declares it to be critical;

3.3.3.3. The Chief Information Officer (CIO) declares it to be critical;

3.3.3.4. The Security Incident Advisory Board (SIAB) declares it to be critical.

3.4. Defining Incident Severity Levels

3.4.1. Information security incident severity levels are based upon all available information about system and data criticality (business impact), sensitivity, and other variables, such as resource requirements and the ability to restore/recover to normal functioning. Categories are as follows:

3.4.1.1. Category 3: Example: Small numbers of system probes or scans detected on internal and/or external systems; isolated instances of malware easily mitigated by endpoint security software; intelligence received concerning threats to which systems may be vulnerable.

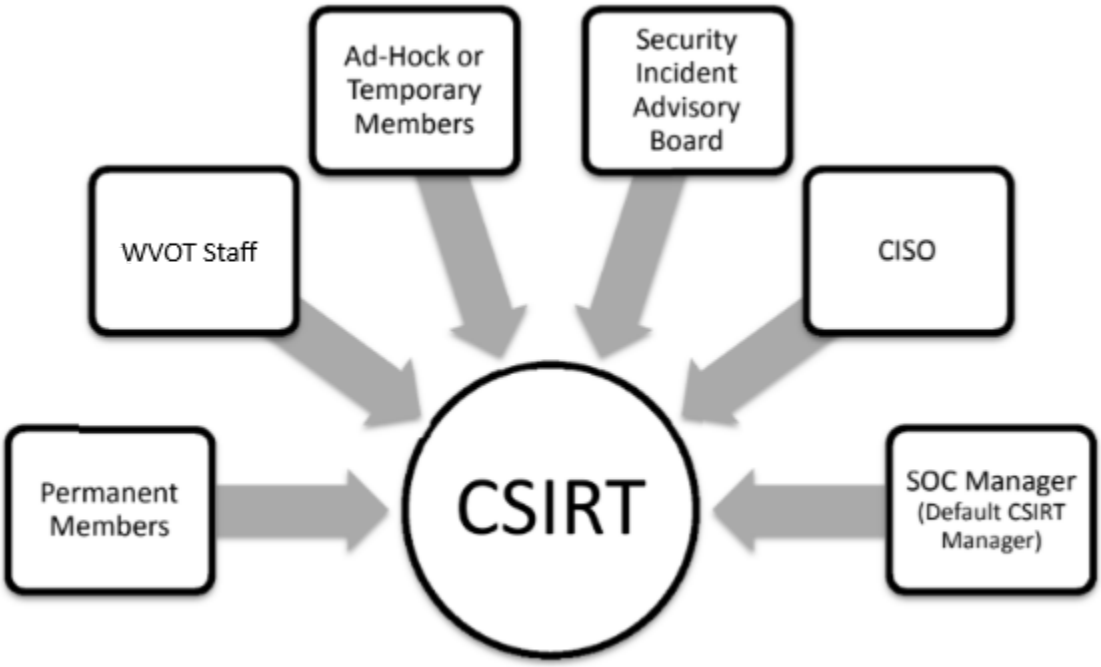
3.4.1.2. Category 2: Example: Significant numbers of system probes or scans detected; Denial of Service attacks attempted with no impact on operations; widespread instances of malware easily mitigated by endpoint security software; isolated instances of a new kind of malware not handled by endpoint security software.

3.4.1.3. Category 1: Example: Successful penetration or Denial of Service attacks, with limited or significant impact on operations; incidents involving sensitive information such as federal tax information (FTI), protected health information (PHI), personally identifiable information (PII), or personal financial information (PFI); widespread instances of a new malware not handled by endpoint security software; significant risk of negative financial or public relations impact; natural disasters, major outages, building shutdown; system failures.

3.5. Responsibilities of the CSIRT

3.5.1. The CSIRT has been established by the CISO to provide detection and effective and orderly response to computer-based security incidents on systems maintained by the WVOT. (For a list of CSIRT duties, see Appendix A.)

3.5.2. The CSIRT will consist of the following members:



3.5.2.1. CSIRT Manager – This individual is responsible for the following:

3.5.2.1.1. Coordinating overall preparation, detection, response, and recovery activities for all security incidents;

3.5.2.1.2. Declaring the severity level of each security incident, and determining the best response and recovery roles;

3.5.2.1.3. Being the primary Point of Contact during a security incident;

3.5.2.1.3.1. Requesting required resources to access and address the incident;

3.5.2.1.3.1.1. Leading the CSIRT Team; and

3.5.2.1.3.1.2. Maintaining a familiarity with security issues, the function of IT areas and staff, and the general practices of State agencies.

3.5.2.2. Security Incident Advisory Board – This board is made up of senior IT staff (ex: the CIO, the CISO, other WVOT Directors as required, and the State Chief Privacy Officer(CPO) or designee. Ad hoc members may include Department Privacy Officers and other mid-to-high level managers throughout various State agencies (ex: ISA, Cabinet Secretary, Legal, Personnel, Media Relations, etc.) experiencing an incident. This group is responsible for making response decisions and budget requests above the level delegated to the CSIRT Manager.

3.5.2.3. Permanent CSIRT Team Members – This team is made up of designated WVOT staff. Members report to the CISO and are responsible for the following:

3.5.2.3.1. Providing ongoing non-response services (i.e.: user education and policy development);

3.5.2.3.2. Assisting the CSIRT Manager in the initial response to Security Incidents or assuming the CSIRT Manager responsibility; and

3.5.2.3.3. Consulting with members of the technical staff.

3.5.2.4. Temporary or ad hoc CSIRT Team Members – These individuals are subject matter experts (SME) (i.e. system owners, data owners, technicians) for the specific systems, applications, and business issues involved in the incident. These members are assigned to an incident at the request of the CSIRT Manager, based upon recommendations from SME supervisors or managers, to serve for the duration of the Security Incident.

3.5.3. When a potential security incident is suspected, CSIRT members must protect the rights of clients, employees, and others as established by law, regulation, and policy, and respond by taking the following steps:

3.5.3.1. Determine if a security incident has occurred and determine the severity of the incident;

3.5.3.2. Determine the impact of the incident (ex: information breach, loss of revenue, productivity, affected systems, affected users, etc.);

3.5.3.3. Select which Ad-Hoc Team members should respond. If FTI, PII, PHI, or other highly sensitive data could be involved, the privacy, or other data-accountable experts, should be included on the Team;

3.5.3.4. Perform damage control of and engage appropriate personnel, as needed, to minimize business interruptions by containing the incident while appropriate technicians are restoring systems to normal function within the organization;

3.5.3.5. Invoke the Security Incident Advisory Board, if appropriate;

3.5.3.6. Establish controls for the proper collection and preservation of evidence, if required;

3.5.3.7. Conduct a post-incident critique;

3.5.3.8. Revise responses as needed to prevent further intrusions; and

3.5.3.9. Document all actions and results.

3.6. Responsibilities of the CISO are as follows:

3.6.1. Briefing the CIO on incidents with potentially great impact.

3.6.2. Briefing the State CPO if the security incident involves PHI or PII.

3.6.3. Facilitating privacy and information security related process and/or security control improvements to reduce the risk of repeated security incidents;

3.6.4. Informing the CIO, as well as other agency management, of information security vulnerabilities that threaten the confidentiality, integrity, or availability of State information, network, or systems;

3.6.5. Providing strategies to mitigate the identified risks; and

3.6.6. Facilitating Security Operation Center (SOC) overtime approval and/or engaging more or alternate resources when responding to Security Incidents.

3.7. Phases of Security Incident Management

3.7.1. Incident Reporting Phase

3.7.1.1. All State employees or users of State systems must immediately report an information security incident by doing one of the following, in this preferred order: (1) filling out an incident at the Incident reporting portal at (https://wv.accessgov.com/technology/Forms/Page/incident-reporting/incident-reporting/) "; (2) contacting the WVOT Service Desk at servicedesk@wv.gov or by phone at 304-558-9966 or 877-558-9966. All employees must provide the following information:

3.7.1.1.1. Point of Contact information for the incident (include name, agency, phone number, email address, and cell/pager numbers);

3.7.1.1.2. Physical location of incident (including building and room numbers, etc);

3.7.1.1.3. Date and time the incident occurred (mm/dd/yy and hh:mm:ss am/pm);

3.7.1.1.4. Is the incident ongoing? (yes/no);

3.7.1.1.5. A brief summary of the reported incident, if known (enter what you think has happened or is happening, i.e. computer or network outage, compromised (hacked) system, information breach, lost or stolen equipment or data, etc.)

3.7.1.1.6. A brief description of the impact of the incident, if known (include the number of known affected critical systems, computers, networks, users, and agencies);

3.7.1.2. Social Security Administration (SSA) information. If your organization experiences or suspects a breach or loss of PII or a security incident, which includes SSA-provided information, they must notify the State official responsible for Systems Security designated in the agreement. That State official or delegate must then notify the SSA Regional Office Contact or the SSA Systems Security Contact identified in the agreement. If, for any reason, the responsible State official or delegate is unable to notify the SSA Regional Office or the SSA Systems Security Contact within one hour, the responsible State organization official or delegate must report the incident by contacting SSA's National Network Service Center (NNSC) toll free at 1-877-697-4889 (select "Security and PII Reporting" from the options list). The organization will provide updates as they become available to SSA contact, as appropriate. Refer to the worksheet provided in the agreement to facilitate gathering and organizing information about an incident.

3.7.1.3. Office of Safeguards Notification Process. Concurrent to notifying TIGTA, the agency must notify the Office of Safeguards by email to Safeguards mailbox, safeguardreports@irs.gov. To notify the Office of Safeguards, the agency must document the specifics of the incident or breach known at that time into a data incident report, including but not limited to:

- Agency name, POC, and contact info for resolving data incident
- Date and time the incident/breach occurred
- Date and time the incident/breach was discovered
- How the incident/breach was discovered
- Description of the incident/breach and the data involved, including specific data elements, if known

- Potential number of FTI records involved; if unknown, provide a range if possible
- Address where the incident/breach occurred
- IT involved (e.g., laptop, server, mainframe)
- Does the incident involve an unauthorized access or disclosure by an agency employee? (Y/N)
- If a criminal indictment is not pursued, will a disciplinary or adverse action be proposed against the agency employee involved in this unauthorized access or disclosure? (Y/N)

3.7.2. Incident Triage and Management Phase

3.7.2.1. The WVOT Service Desk will log the incident report as SEV 1 and forward the above information to Enterprise Security. The CSIRT Manager will contact the reporting individual, or will assign a CSIRT member to contact the individual to confirm that a security incident did occur. The CSIRT Manager or member will complete a Security Incident Report Form by asking pertinent questions related to the incident.

3.7.2.2. In the event that a security incident has occurred and appropriate staff is already in the response phase, the CSIRT Manager will brief appropriate individuals, and make sure the CSIRT Team has all needed resources.

3.7.2.3. Following the interview, the CSIRT Manager or member will determine the number of impacted employees and/or constituents, as well as the severity level of the incident. Severity levels will be managed as follows:

3.7.2.3.1. Category One

3.7.2.3.1.1. Any and all available resources will be engaged to stop the incident from continuing, if it is ongoing, to minimize further damage/consequence.

3.7.2.3.1.2. The Security Incident Advisory Board will be notified, and CSIRT members will be dispatched to assist as needed.

3.7.2.3.1.3. The CSIRT will bring in law enforcement, if needed.

3.7.2.3.1.4. The CSIRT, taking direction from the Security Incident Advisory Board, will decide whether the main objective will be to protect data/systems (i.e., get system operational as soon as possible) or to pursue an investigation (i.e., gather evidence for prosecution,alert the Security Incident Advisory Board, system owners, and the Agency Legal Department, etc.).

3.7.2.3.1.5. The CISO will notify, as necessary, the CIO, the State CPO, business units, and/or affected agencies.

3.7.2.3.1.6. Incident Response Phase will be initiated.

3.7.2.3.2. Category Two and Three

3.7.2.3.2.1. Handled locally by system owner and/or support with CSIRT members standing by for assistance, if needed.

3.7.2.3.2.2. The CISO will notify, as necessary, the CIO, the State CPO (where applicable), business units, and/or affected agencies.

3.7.2.3.2.3. Incident Response Phase will be initiated.

3.7.3. Incident Response Phase

3.7.3.1. During this phase, CSIRT members will perform the following tasks:

3.7.3.1.1. Gather and analyze evidence (log files,audit trails, etc.) to determine (1) how to stop the incident; (2) the cause of the incident; (3) the vulnerability or vulnerabilities being exploited; (4) how to eliminate vulnerabilities; and (5) additional mitigation activities.

3.7.3.1.2. Make an assessment of how far the incident has spread, i.e., which systems are involved, and the extent that have been compromised.

3.7.3.1.3. If a privacy violation has occurred, appropriate response to breach law, including notifications, should be completed.

3.7.4. Incident Recovery Phase

3.7.4.1. During this phase, the CSIRT is responsible for the following:

3.7.4.1.1. Reporting any damage and/or the status of affected systems to the CSIRT Manager;

3.7.4.1.2. Monitoring restoration of affected systems to normal operation, adhering to current and prevailing disaster recovery plans;

3.7.4.1.3. Assuring testing of the systems to make sure they are no longer vulnerable to attack, and that they will function correctly when placed back into production; and

3.7.4.1.4. Consulting with the Security Incident Advisory Board, Legal Counsel, and impacted agency leadership, about possible notification of any breach to the media and/or the potential victims.

3.7.5. Maintenance Phase

3.7.5.1. As soon as possible after an incident has closed, CSIRT members, in collaboration with the Security Incident Advisory Board (SIAB), will schedule a “lessons learned” meeting in order to identify potential problems and/or deficiencies. At a minimum, the following items should be evaluated:

3.7.5.1.1. Security-related incident response policies and procedures;

3.7.5.1.2. Tools and resources used during incident response;

3.7.5.1.3. Team model and structure;

3.7.5.1.4. Incident responder training and education;

3.7.5.1.5. Incident documentation and reports;

3.7.5.1.6. Mitigation action(s) to prevent similar future security incidents;

3.7.5.1.7. Any factors that may have inhibited recovery;

3.7.5.1.8. The measures of success (ex: incident containment, eradication, and recovery); and

3.7.5.1.9. The cost of the incident to State government.

3.7.5.2. CSIRT members must create a follow-up report after each security incident, to provide guidance in handling future incidents. These reports (Appendix B) will be sent to the reporting agency, and must be kept by the CSIRT for a minimum of five years. The report should contain:

3.7.5.2.1. Incident Identifier

3.7.5.2.2. Documentation Location

3.7.5.2.3. Date of Incident

3.7.5.2.4. SIAB Members, CSIRT Members

3.7.5.2.5. Known costs associated with Incident

3.7.5.2.6. Magnitude of Incident (number of notifications, etc.)

3.7.5.2.7. Remediation actions

3.7.5.2.8. Process changes to prevent incident from reoccurring.

3.7.5.2.9. Report Date.

3.7.5.2.10. CIO and CISO signoff

3.7.5.2.11. Distribution to...(if any)

3.7.5.3. CSIRT members should review all related documentation and procedures for managing security incidents annually.

4. DEFINITIONS

4.1. Availability – Having reliable and timely access to the data and resources you are authorized to use.

4.2. Chief Information Security Officer (CISO) – Person designated by the CIO to oversee Information Security practices and initiatives for the Executive Branch of WV State government, excluding the constitutional officers.

4.3. Chief Information Officer (CIO) – The person responsible for the State's information resources.

4.4. Computer Security Incident Response Team (CSIRT) – A group of individuals who have been trained in computer security incident management, each having distinct response roles, and a familiarity with the fundamentals of gathering and handling evidence. Members of this team must be adequately skilled, possess general expertise about various information systems, be on call twenty-four hours a day, and be capable of responding within a nominal amount of time.

4.5. Computer Incident Response Team (CSIRT) Manager – Designated leader of the CSIRT, who has direct communication with upper management during a security incident response. They will coordinate and dispense critical information to both upper and middle management.

4.6. Confidentiality – The concept of keeping private information away from individuals who should not have access.

4.7. Contractor – Anyone who has a contract with the State or a state entity..

4.8. Denial of Service (DoS) Attack – attack that prevents or impairs authorized use of networks, systems, or applications by overloading resources.

4.9. Information Assets – Any of the data, hardware, software, network, documentation, and personnel used to manage and process information.

4.10. Information Security incident - Any known successful or unsuccessful attempt by an authorized or unauthorized individual to inappropriately use, disclose, modify, access, or destroy any electronic information.

4.11. Integrity – maintains that data is consistent and hasn’t been modified.

4.12. West Virginia Cybersecurity Office (CSO) - The functional unit charged with the responsibility to undertake and sustain initiatives to promote, enhance, monitor, and govern actions, standards, and activities necessary to safeguard data and information systems within the Executive Branch of WV, as provided in West Virginia Code §5A-6-4a and the Governor's Executive Order No. 6-06.

4.13. Personally Identifiable Information (PII) –Includes all protected and non-protected information that identifies, or can be used to identify, locate, or contact an individual.

4.14. Privacy Incident– A breach in which there is knowledge or reasonable belief that there has been, or may have been, unauthorized or inappropriate collection, use, access, disclosure, modification, and/or exposure of PHI or PII.

4.15. Protected Health Information (PHI) – Health information transmitted by or maintained in electronic media used to identify an individual, which is created, used, or disclosed in the course of providing health care services such as diagnosis or treatment. Examples include: names, phone numbers, medical record numbers, photos, etc.

4.16. Security Incident Advisory Board (SIAB) - This board is comprised of senior IT staff and other mid-to-high level managers throughout various State agencies, as well as ad-hoc, incident-specific, members. This group is responsible for making response decisions and budget requests above the level delegated to the CSIRT Manager.

4.17. Security Operations Center (SOC) – The SOC is part of WVOT's Information Security Team that focuses on monitoring activities, investigations, forensics, WEB monitoring/site blocking, and other system safeguards.

4.18. State Chief Privacy Officer (CPO) – An individual who oversees all ongoing Executive Branch activities related to the development, implementation, maintenance of, and adherence to the applicable laws, policies, and procedures governing privacy.

4.19. West Virginia Office of Technology (WVOT) - The division of the Department of Administration established by WV Code § 5A-6-4a, et. seq., which is led by the State's CIO and designated to acquire, operate, and maintain the State's technology infrastructure. The WVOT is responsible for evaluating equipment and services, and reviewing information technology contracts.

5. RELEVANT MATERIALS AND DOCUMENTS

5.1. Appendix A - Computer Security Incident Response Team (CSIRT) Duties

5.2. Appendix B - Incident Follow-up Report

5.3. Appendix C - Quick Reference Guide

APPENDIX A: Computer Security Incident Response Team(CSIRT) Duties

The CSIRT Manager will be responsible for the following duties:

• Assist in the development and promotion of security policy and procedures, such as password and intrusion detection policies, as well as backup and recovery procedures.

• Select and train Computer Security Incident Response Team (CSIRT) members and coordinators, as well as standing Advisory Board members.

• Develop a representative inventory of critical security incidents, based upon historical incident events.

• Maintain information security incident response handling procedures regarding notification, assessment, investigation, remediation, monitoring, and reporting to CISO.

• Maintain procedures or protocols to report criminal-related security incidents to outside authorities complying with appropriate legal requirements and regulations, including who the reporting official should be under differing circumstances, and to whom the official should report the various incident types.

• Inform and coordinate security incident response activities within the CSIRT.

• Maintain documentation related to security incidents, such as, how it occurred, where the attack came from, the response, and whether the response was effective.

• Preserve evidence, i.e., keep lists of witnesses, maintain copies of logs, e-mail, and other communication; maintain a chain of custody of evidence.

• Take action to prevent further intrusion or damage and remove the cause of the problem.

• Determine source of intrusion and take steps to prevent an immediate re-infection.

• Coordinate CSIRT's restoration of affected systems to their original state and preserve evidence by backing up logs or possibly the entire system while minimizing business interruptions.

• Assess the damage to the State and estimate both the damage cost and the cost of the containment efforts.

• Conduct a post-incident evaluation of the incident characteristics, and the incident response activities, and revise procedures, response planning, and policies, as needed to reduce the risk of future incidents, and improve the response methodology.

APPENDIX B: Incident Follow-up Report

Incident Identifier_____ **Date of Incident**_____

Documentation Location_____

SIAB Members_____

_____

CSIRT Members_____

_____

Other Ad-Hoc Members_____

Known and Unknown Costs_____

Magnitude of Incident
(e.g. number of notifications, etc.)_____

_____

Recommendations
(e.g. process changes, equipment purchases)_____

_____

_____ _____
CIO Signature / Date CISO Signature / Date

Distribution to:

APPENDIX C: Incident Management Plan Quick Reference Guide

Suspected Security Incident Occurs	A Security Incident is any event that involves misuse of computing resources or is disruptive to normal system or data processing operations.
Notification of Incident	An incident is immediately reported to: https://wv.accessgov.com/technology/Forms/Page/incident-reporting/incident-reporting/ or email incident@wv.gov or call the WVOT Service Desk at (877) 558-9966. Take immediately available action to stop or limit additional harm or consequences from the incident.
Incident Triage and Management	Security incidents range in severity from Non-Critical to Critical. The categorization of an incident, according to its severity. Temporary or ad hoc CSIRT members are assigned as appropriate to the incident. Security Incident Advisory Board (SIAB) is invoked, if appropriate.
Incident Response	Gather and analyze evidence (log files, audit trails, etc.) to determine (1) how to stop or limit ongoing harm or consequence from the incident; (2) the cause of the incident; (3) the vulnerability or vulnerabilities being exploited; (4) how to eliminate vulnerabilities; and (5) additional mitigation activities.
Incident Recovery	Assuring testing of the system(s) to make sure they are no longer vulnerable to attack, and that they will function correctly when placed back into production.
Maintenance	CSIRT members, in collaboration with the Security Incident Advisory Board (SIAB), if appropriate, will schedule a “lessons learned” meeting to identify potential problems and/or deficiencies.